

电车票务数据平台— 安全技术部说明文档

适用范围：有轨电车公司信息管理系统

编制日期：2026-07-30

对应版本：v1.0

一、软件概述

1.1 软件名称

电车票务数据平台（下文简写为TRAM）

1.2 软件定位

TRAM 是一个**纯读取型** Web 数据浏览与导出工具。它连接公司现有 Oracle 数据库（有轨电车管理信息系统），通过浏览器向授权用户提供运营数据表的在线浏览和 Excel 导出功能。核心应用场景为**每日运营数据清分**（客流清分 / 结算清分）。

1.3 软件架构

组件	技术选型	说明
数据库连接	Python oracledb (thin 模式)	纯 Python 驱动，无需安装 Oracle Instant Client
Web 后端	Python Flask + waitress	Windows 生产级 WSGI 服务器
用户认证	SQLite + Flask-Login	自包含用户库，管理员 / 普通用户双角色
Excel 生成	openpyxl (write_only)	流式写入，不将整表加载到内存
前端界面	Bootstrap 5 (CDN)	中文界面，响应式布局，无需构建步骤

1.4 部署位置

部署于公司内网 Windows 服务器，授权用户通过内网浏览器访问（HTTP）。

二、软件作用

2.1 核心功能

- 数据表浏览：**自动发现 Oracle 数据库中授权可见的数据表，按 Schema 分组展示，支持按表名搜索，行数颜色编码。
- 表结构查看：**展示每张表的列名、数据类型、长度、是否可空等元数据信息。
- 数据预览：**在线预览表内前 100 行数据，无需导出即可快速查看。
- 日期范围筛选：**自动检测表中所有 DATE / TIMESTAMP 类型列，支持按日期范围精准筛选数据后导出。
- Excel 流式导出：**将查询结果导出为 .xlsx（或 .csv）文件，边读边写、流式传输，不消耗服务器大量内存。

- 6. **超大表分片下载**：超过 500 万行的表自动拆分为多个 Excel 文件，逐片独立下载，避免单次请求超时或内存溢出。
- 7. **用户权限管理**：管理员可创建 / 禁用 / 删除用户，普通用户只能浏览和下载数据。支持修改密码。
- 8. **系统诊断面板**：管理员可查看服务器硬件状态、Oracle 连接延迟、表统计信息、当前安全配置等。

2.2 解决的问题

- **消除人工导出依赖**：运营人员不再需要联系 DBA 或使用 SQL 工具手动导出数据，直接在浏览器中自助完成。
- **统一数据出口**：所有清分数据通过同一平台导出，格式统一（.xlsx），避免多人多版本 SQL 脚本造成的数据口径不一致。
- **安全管控**：通过用户认证、权限分级、下载安全分层、表过滤白名单/黑名单等机制，确保数据访问可管可控。

三、安装原因

3.1 业务需求

- 1. **每日清分工作刚性需求**：运营部门每日需从 Oracle 数据库中提取客流清分表和结算清分表，当前依赖人工 SQL 查询或 DBA 协助，效率低且存在误操作风险。
- 2. **多部门数据共享**：财务、调度、运营分析等多个岗位均需定期获取票务数据，需要一个统一、安全、可审计的数据出口。
- 3. **降低数据库直接访问风险**：通过本平台统一代理数据查询，可收回各终端用户直接登录数据库的权限，避免人为误操作（如误执行 UPDATE/DELETE 语句）。

3.2 技术合理性

- 1. **最小权限原则**：平台只需 Oracle 账号的 SELECT 权限即可运行，无需 INSERT、UPDATE、DELETE 或 DDL 权限。
- 2. **零侵入部署**：不修改数据库任何对象（不建表、不建视图、不建存储过程），不安装数据库端 Agent。
- 3. **流式架构保护服务器**：数据从 Oracle → Python 生成器 → Excel 流 → 浏览器，全程流式传输，不落盘缓存，不占用大量内存。

四、安装说明

4.1 环境要求

项目	要求
操作系统	Windows Server 2016+ 或 Windows 10/11
Python	3.9 及以上（ python.org 下载，安装时勾选 "Add Python to PATH"）
网络	能够访问目标 Oracle 数据库（默认端口 1521）
浏览器	Chrome / Edge / Firefox 最新版（客户端）

4.2 安装步骤

步骤一：部署程序文件

将 **tram** 目录完整复制到目标服务器上（如 **D:\tram**），目录结构如下：

```
tram/
├── app.py           # 主应用程序
├── config.py        # 配置文件
├── auth.py          # 用户认证模块
├── db_oracle.py      # Oracle 数据库连接模块
├── db_demo.py        # 演示模式模块（无需 Oracle）
├── export.py         # Excel/CSV 导出模块
├── init_db.py        # 用户数据库初始化
├── requirements.txt  # Python 依赖清单
├── start.bat         # Windows 一键启动脚本
└── templates/       # 前端页面模板
```

步骤二：配置 Oracle 连接

编辑 **start.bat** 文件顶部的环境变量：

```
set ORACLE_USER=tram           # Oracle 用户名（建议专用只读账号）
set ORACLE_PASSWORD=tram123    # Oracle 密码
set ORACLE_DSN=192.168.1.100:1521/ORCL  # Oracle 连接串
set WEB_PORT=8080              # Web 服务端口
```

也可通过 Windows 系统环境变量设置（优先级高于 bat 文件内设置）。

步骤三：配置表过滤（可选但建议）

为限制可见的数据表范围，建议设置白名单模式：

```
set TABLE_FILTER_MODE=whitelist
set TABLE_FILTER_PATTERNS=["DAILY%", "CLEARING%", "PASSENGER%", "TXN%"]
```

步骤四：启动服务

双击 **start.bat**，脚本将自动完成：

1. 检查 Python 环境
2. 创建虚拟环境（首次）
3. 安装依赖包（Flask、oracledb、openpyxl、waitress、psutil）
4. 初始化用户数据库（创建默认管理员账号）
5. 启动 waitress Web 服务器

步骤五：验证访问

- 本机访问：**http://localhost:8080**

- 内网其他电脑访问：<http://<服务器IP>:8080>
- 默认管理员账号：[admin / Admin@tram2026](#)（首次登录后请立即修改密码）

4.3 注册为 Windows 服务（可选，实现开机自启）

使用 [NSSM](#)（Non-Sucking Service Manager）：

```
nssm install TramDataExport
# Application: D:\tram\venv\Scripts\python.exe
# Arguments: -c "from waitress import serve; from app import create_app;
serve(create_app(), host='0.0.0.0', port=8080)"
# Start directory: D:\tram
nssm start TramDataExport
```

4.4 Oracle 账号权限要求

⚠ 重要：本平台仅需 Oracle 的 **SELECT** 权限（以及对 **ALL_TABLES**、**ALL_TAB_COLUMNS** 等数据字典视图的查询权限）。请为平台创建专用只读账号，**严禁授予 INSERT / UPDATE / DELETE / DROP / ALTER 等写权限。**

建议的 Oracle 账号授权语句（由 DBA 执行）：

```
GRANT CONNECT TO tram;
GRANT SELECT ON tram.DAILY_PASSENGER_FLOW TO tram;
GRANT SELECT ON tram.CLEARING_DAILY TO tram;
-- ... 按需逐表授权
```

五、核心安全保障：只读设计

⚠ 本节为安全审查重点，请仔细阅读。

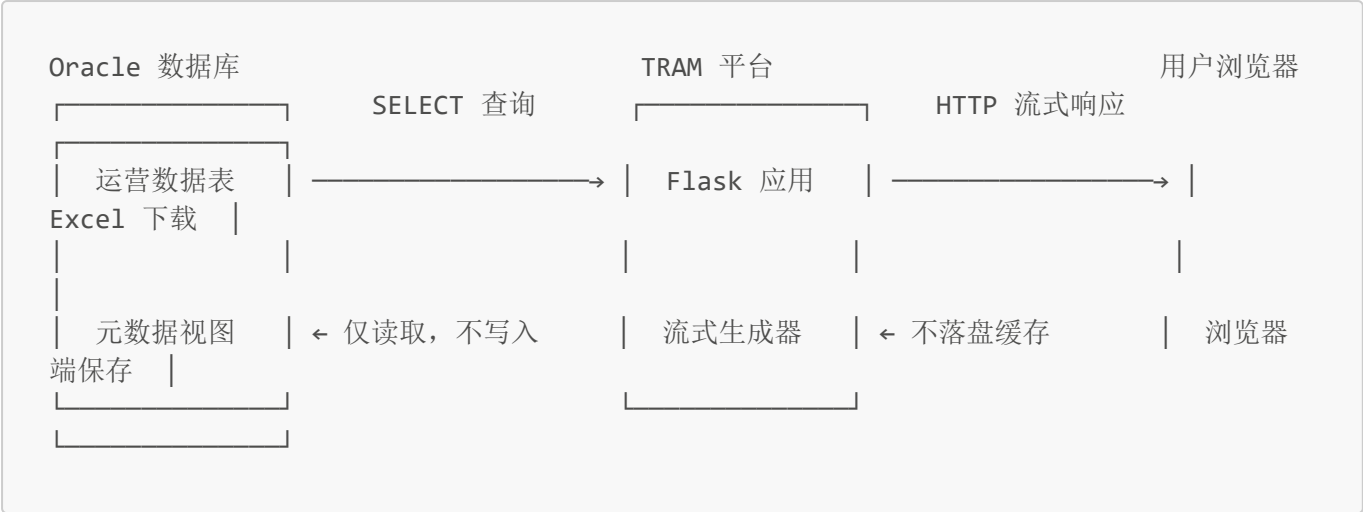
5.1 软件本身不修改数据库数据

TRAM 平台对 Oracle 数据库仅执行 SELECT 查询，不执行任何 INSERT、UPDATE、DELETE、MERGE、TRUNCATE、DROP、ALTER、CREATE 等写操作。

5.2 代码层面证明

1. **无写操作代码：**经审查全部源代码（[app.py](#)、[db_oracle.py](#)、[db_demo.py](#)、[export.py](#)），应用程序中不包含任何数据库写操作语句。所有 SQL 均为 **SELECT** 查询。
2. **无 DDL 操作：**不创建表、视图、存储过程、触发器等数据库对象。
3. **无事务写操作：**不开启写事务，不对数据库提交任何变更。
4. **连接仅用于读取：**Oracle 连接池（2~10 连接）仅用于执行 SELECT 查询和读取元数据视图。

5.3 数据流向说明



- **数据库端：**TRAM 仅发送 SELECT 语句和参数化查询。
- **服务端：**数据以生成器（Generator）方式流式传输，不在服务器磁盘上创建临时文件。
- **客户端：**数据以 HTTP 流式响应到达浏览器，浏览器触发文件下载。

5.4 不会干扰日常业务

1. **连接池限制：**最大 10 个数据库连接，不会占用大量数据库会话资源。
2. **查询均为快照读：**Oracle SELECT 查询不加锁，不会阻塞业务写入。
3. **无长事务：**每次查询独立提交连接，不持有锁资源。
4. **下载安全分层：**超大表自动拒绝单次下载，引导用户缩小日期范围或使用分片，避免长时间查询占用资源。
5. **流式读取：**每次从 Oracle 仅取 1000 行（可配置），分批获取，不会一次性锁住大量数据页。

六、安全机制详细说明

6.1 用户认证与授权

安全措施	实现方式
密码存储	werkzeug scrypt 算法哈希，不存储明文
会话管理	Flask-Login，8 小时过期，HttpOnly Cookie
权限分级	管理员（可管理用户） / 普通用户（仅浏览下载）
账号保护	管理员不能删除/禁用自己；登录失败提示不区分用户名/密码错误
密码策略	最小长度 6 位；管理员可重置密码（生成随机密码）；用户可自行修改

6.2 SQL 注入防护

防护层	措施
表名 / Schema 名	正则白名单校验 <code>^[A-Za-z0-9_#\$st]+</code> ，不通过则拒绝请求
日期列名	先查询表中实际列信息，确认列名真实存在后拼入 SQL
日期参数值	使用 Oracle 绑定变量 <code>:date_start</code> / <code>:date_end</code> ，不直接拼接

防护层	措施
搜索关键字	通过参数化查询传入，非字符串拼接

6.3 下载安全控制

分级	行数范围	行为
safe	< 10 万行	直接下载，无警告
large	10 万 ~ 50 万行	显示提示信息，可直接下载
huge	50 万 ~ 500 万行	警告提示，需用户确认后才下载；建议使用分片
blocked	> 500 万行	拒绝直接下载，仅允许分片下载

附加保护：

- **内存检查：**下载前估算文件大小，若超过服务器可用内存的 60% 则拒绝；若可用内存低于 15% 则拒绝大表下载。
- **行数硬上限：**单次下载硬上限 500 万行（可配置），超限自动拒绝。
- **分片下载：**超大表每片 50 万行（可配置），逐片下载。

6.4 表可见性控制

- 默认排除 Oracle 系统 Schema（SYS、SYSTEM 等 30+ 个）
- 支持白名单模式（仅显示匹配的表）
- 支持黑名单模式（排除匹配的表）
- 支持额外排除指定 Schema

6.5 传输安全

- **HttpOnly Cookie：**防止客户端脚本读取会话令牌
- **内网部署：**默认 HTTP（内网环境）。如需 HTTPS，可前置 Nginx 反向代理

七、现场安全性提示

7.1 部署前检查

1. ☐ Oracle 账号**仅授予 SELECT 权限**，确认不具备 INSERT / UPDATE / DELETE / DROP 等写权限。
2. ☐ 服务器防火墙规则：仅对内网开放 Web 端口（默认 8080），**不对公网开放**。
3. ☐ Python 安装来源为官方 python.org，校验数字签名。
4. ☐ 依赖包从 PyPI 官方源安装，不通过第三方镜像（可配置内部镜像）。
5. ☐ `instance/users.db` 文件仅管理员可访问，设置 NTFS 权限限制。
6. ☐ 首次部署后立即修改默认管理员密码。

7.2 运行中注意事项

1.  **定期审计用户账号：**通过管理面板检查活跃用户，及时禁用离岗人员账号。
2.  **定期检查 Oracle 连接日志：**确认无不正常的大批量查询或异常时段访问。
3.  **服务器资源监控：**关注 CPU、内存、磁盘使用率。本软件流式传输不落盘，磁盘占用极小。

4.  **不要直接修改 `instance/users.db`**：用户数据库操作通过 Web 管理界面完成。如忘记管理员密码，删除该文件后重启将重建默认管理员。
5.  **重要提示**：如需停止服务，直接关闭命令行窗口（或停止 Windows 服务）。无数据丢失风险（因为本软件不存储任何 Oracle 数据）。

7.3 网络安全建议

1. 服务仅绑定内网 IP（`0.0.0.0` 用于内网所有网卡），确保防火墙不允许外网访问 Web 端口。
2. 建议将部署服务器的远程桌面（RDP）和文件共享限制为仅管理员网段可访问。
3. 如有多网段访问需求，建议通过网络 ACL 限制可访问 Web 端口的源 IP 范围。

八、应急处理办法

8.1 服务不可用

现象	可能原因	处理步骤
浏览器无法打开页面	服务进程退出	① 远程登录服务器，重新双击 <code>start.bat</code> ；② 如已注册为 Windows 服务，运行 <code>nssm restart TramDataExport</code>
页面显示"连接 Oracle 数据库失败"	Oracle 不可达	① 检查 Oracle 服务器是否正常运行；② 从服务器 ping Oracle IP；③ 检查防火墙 1521 端口；④ 检查 <code>ORACLE_DSN</code> 配置是否正确
页面能打开但显示数据库错误	Oracle 账号过期/锁定	联系 DBA 检查 Oracle 账号状态，确认 SELECT 权限有效
下载大表时页面卡住	查询耗时较长	耐心等待；如超过 10 分钟无响应，刷新页面，改为使用日期筛选缩小范围后再下载

8.2 安全事件

现象	处理步骤
怀疑账号泄露	① 管理员立即禁用可疑账号（管理面板 → 禁用）；② 重置该账号密码；③ 在管理面板检查是否有陌生账号；④ 检查 Oracle 审计日志确认数据访问范围
发现未授权访问	① 立即关闭服务进程（关闭命令行窗口或 <code>nssm stop TramDataExport</code> ）；② 检查 <code>instance/users.db</code> 中的用户列表；③ 检查 Web 服务器访问日志；④ 修复安全问题后重新启动
服务器资源异常	① 检查是否有大量并发下载；② 降低连接池上限（编辑 <code>config.py</code> 中 <code>oracledb pool max</code> 值）；③ 必要时重启服务

8.3 服务停止方法

方法一（命令行窗口启动）：直接关闭命令行窗口，或按 `Ctrl+C`。

方法二（Windows 服务启动）：

```
nssm stop TramDataExport    # 停止服务
nssm start TramDataExport    # 重新启动
nssm remove TramDataExport   # 彻底删除服务
```

8.4 管理员密码重置

如果忘记管理员密码且无其他管理员账号可用：

1. 停止服务
2. 删除 `tram\instance\users.db` 文件
3. 重新启动服务（`start.bat` 或启动 Windows 服务）
4. 系统将自动重建默认管理员账号：`admin / Admin@tram2026`
5. 登录后立即修改密码

注意：此操作会删除所有用户账号，需重新创建。如未停服即删库，需在停止服务后删除文件再重启。

8.5 数据验证与对账

由于本平台是纯读取工具，若导出的数据与预期不符：

1. 在 Oracle 中执行相同条件的 COUNT 查询确认行数是否一致。
2. 检查是否设置了日期筛选条件（日期筛选会影响导出数据范围）。
3. 对比 Excel 行数（减去表头 1 行）与平台显示的预估行数。
4. 平台表预览页展示的行数和文件大小均为实时查询结果，与导出数据一致。

九、联系方式与技术支持

角色	说明
系统部署 / 运维	由信息中心负责服务器环境和网络配置
Oracle 账号管理	由 DBA 负责创建只读账号和表权限分配
应用问题反馈	联系开发团队

十、附录

10.1 依赖包清单

包名	版本	用途	许可证
Flask	≥3.0, <4.0	Web 框架	BSD
Flask-Login	≥0.6, <1.0	用户会话管理	MIT
oracledb	≥2.0,  .0	Oracle 数据库驱动	Apache 2.0
openpyxl	≥3.1, <4.0	Excel 文件生成	MIT

包名	版本	用途	许可证
waitress	≥3.0, <4.0	WSGI 服务器	ZPL 2.1
psutil	≥5.9, <7.0	硬件资源探测	BSD

10.2 关键配置文件

所有配置项均支持环境变量覆盖，详见 [config.py](#)。主要配置项：

配置项	默认值	说明
ORACLE_USER	tram	Oracle 连接用户名
ORACLE_DSN	localhost:1521/ORCL	Oracle 连接串
WEB_PORT	8080	Web 服务端口
MAX_DOWNLOAD_ROWS	5,000,000	单次下载行数硬上限
DOWNLOAD_CONFIRM_ROWS	500,000	需要确认的行数阈值
DOWNLOAD_WARN_ROWS	100,000	需要提示的行数阈值
PERMANENT_SESSION_LIFETIME	28,800 秒（8 小时）	会话过期时间
DEMO_MODE	0	设为 1 启用无 Oracle 演示模式

10.3 数据表分级示例

以下为演示模式内置的 8 张仿真电车运营表，覆盖全部分级场景：

表名	Schema	行数	分级	说明
STATION_INFO	TRAM	85	● safe	站点基础信息
VEHICLE_SCHEDULE	TRAM	3,650	● safe	车辆调度计划
CLEARING_DAILY	TRAM	72,000	● safe	每日清分结算
DAILY_PASSENGER_FLOW	TRAM	95,800	● safe	每日客流统计
ROUTE_OPERATION	TRAM	120,000	● large	线路运营记录
TXN_TICKET_SALES	TRAM	450,000	● huge	票务销售交易明细
PASSENGER_FLOW_HOURLY	TRAM	2,100,000	● huge	小时级客流明细
TXN_HISTORY_2024	TRAM_ARCHIVE	12,000,000	● blocked	2024年交易归档（需分片）

结论：TRAM 电车票务数据平台是一个**纯读取型**数据浏览与导出工具，对 Oracle 数据库仅执行 SELECT 查询，不修改任何业务数据，不会干扰日常数据库写入和业务运行。平台通过多层安全机制（用户认证、权限分级、SQL 注入防护、下载安全分层、连接池限制）保障数据访问安全。请安全技术部审核。